

PRODUCT & RELEASE REVIEW

Codexa Bounded Causal Change Intelligence

Bounded, deterministic relationship evidence for Codexa's existing change-governance flow.

PR summary for codex/context-intelligence-next against main.

- Base: c306c1d (v0.18.0)
- Validated feature source head: 0474276; published as 869257e
- CI hardening head: 41118bb; published as 9c29408
- First review hardening head: a6ac9d0; published as 05a1dc3
- Final code head: 2e0c140
- Final code tree: 78bfea34aca04cf7236ddfc0d43655fab1d50ba3
- Branch delta before this evidence refresh: 70 files, 6,159 insertions, 288 deletions
- Commits before this evidence refresh: 12 Conventional Commits - 6591e60 - feat: add bounded causal change intelligence - 0474276 - test: accept SDK validation wording - d18637f - docs: add context intelligence PR summary - 41118bb - fix(bootstrap): preserve first terminal condition - 3e2608a - docs: refresh context intelligence review evidence - a6ac9d0 - fix(workflow): preserve capped membership authority - 3fa989c - docs: record workflow membership review fix - balf090 - fix(workflow): retain exact capped membership - c815415 - docs: finalize context intelligence release evidence - 4862bb4 - perf(startup): attest compact index status - leecdd8 - fix(index): bind witness to serialized snapshot - 2e0c140 - fix(index): recognize typed MCP server receivers

Executive Outcome

Codexa now explains a proposed or completed change through bounded, source-backed causal evidence: the declared edit target, the runtime or workflow path it participates in, nearby blast-radius evidence, and the tests that can verify it. The same evidence model follows change planning, post-edit review, committed change review, and proof without granting itself edit authority or changing a readiness verdict.

This keeps Codexa in its lane. GitNexus- and Graphify-style relationship value is delivered inside Codexa's existing local governance and completion flow; there is no graph database, graph query language, vector service, UI, new MCP tool, cross-repository crawler, or embedded model call.

The implementation uses a functional-core/imperative-shell design: immutable facts, explicit typed transitions, deterministic fingerprints, pure bounded selection, stable tie-breaking, and side effects confined to existing index and snapshot boundaries.

Highest-ROI Adjustments

1. One evidence model across the completion lifecycle

- Adds schema-validated evidence bundles to change plans, task snapshots, post-edit review, committed review, and proof cards.
- Preserves original edge direction and provenance on every chain segment.
- Separates caller-authorized edit targets from inferred read dependencies and verification targets. Evidence can explain scope; it cannot widen scope.
- Keeps evidence advisory: it cannot promote authority, readiness, or verdicts.
- Carries stable snapshot, task, chain, and bundle identities through MCP compaction, with explicit counts, gaps, and truncation receipts.

2. Framework execution surfaces become useful graph evidence

- Indexes Commander CLI roots, aliases, subcommands, singleton and namespace forms, plus CommonJS destructuring and namespace usage.

- Indexes MCP tool registrations, including bounded helper-wrapper discovery.
- Follows exact MCP receiver provenance through current-file typed options, Pick projections, destructuring, renamed bindings, and property access.
- Resolves lexical declaration identity so shadowed `program`, `Command`, `server`, and helper names cannot create false workflows.
- Rejects control-character names and unrelated look-alike receivers.
- Keeps a cold production-source contract between every derived MCP workflow and the authoritative 23-tool registry, preventing stale cache data from masking parser drift.
- Uses one-pass workflow evidence indexes and production-first bounding so test fan-out cannot evict the runtime implementation from a workflow packet.

3. Deterministic, database-free causal traversal

- Bounds a bundle to 3 chains, 6 segments per chain, depth 4, 12 paths, 4 tests, 4 gaps, 4,096 visited nodes, 16,384 examined edges, and 8 analyzed targets.
- Preserves deterministic output under edge-order permutations and diamond graphs through canonical ordering and explicit tie-breaking.
- Stores canonical adjacency references in `Uint32Array` form and materializes neighbor objects only during the bounded traversal.
- In a 500,000-edge fixture, retained adjacency fell from about 160 MiB to exactly 4,000,000 bytes (about 3.8 MiB), roughly a 40x reduction; setup stayed near 1.3 seconds. Retained references are capped at 8 bytes per edge.

4. Safe index and transport evolution

- Advances the derived index revision to 4. Earlier indexes remain readable but stale and rebuild; revision-4 indexes fail closed if exact workflow membership is missing or malformed. The parse-cache revision also advances so prior parser results cannot survive changed execution-surface semantics.
- Persists only the paths omitted by public workflow caps in an internal `workflowMembershipSpill` map. Every public workflow, MCP, facts, and relational projection remains unchanged and bounded.
- Uses the same 512 MiB UTF-8 limit in the writer and loader. Oversized indexes fail before atomic replacement, so the writer cannot publish an artifact the loader would reject.
- Preserves workflow truncation receipts and evidence identity through compact MCP profiles.
- Keeps existing public commands and MCP tools intact; the change enriches their evidence rather than introducing another overlapping surface.
- Publishes a compact `index-integrity.json` witness in the same atomic index bundle. It binds exact index/freshness byte lengths and SHA-256 digests to the current revision and checkout snapshot identity.
- Validates current-revision array shape and exact workflow membership before issuing the witness. Status and `SessionStart` stream-hash the bounded index with no-follow, single-link, stable-descriptor, and final-path checks instead of materializing the full JSON object. Missing, legacy, torn, or mismatched witnesses fall back to the established full parser and remain fail-closed.
- Updates `@modelcontextprotocol/sdk` from 1.29.0 to 1.30.0. Codexa's response budget remains at most 512 KiB, well below the SDK's 10 MiB stdio input cap. The resolved dependency audit is clean.

Human Workflow Simulation

An exact-head disposable JavaScript checkout service was exercised through the same sequence a developer uses: initialize, index, inspect, plan, edit, observe staleness, auto-refresh, test, post-edit review, proof, commit, and strict committed review. Codexa indexed 10 files, 12 symbols, 68 usage sites, zero parser errors, and both the Commander checkout and MCP checkout workflows.

The saved plan explicitly authorized one implementation and one test file. A quantity-limit edit made status report `stale (dirty-files-changed)`; repo-map then auto-refreshed to `fresh-with-dirty-overlay`. Four real Node tests and a direct boundary smoke passed. Post-edit review returned `continue` with complete 2/2 coverage, no scope drift, and completion authority `complete`; proof was `ready` with zero gaps. After the `Conventional Commit feat(pricing): cap checkout line quantity`, strict committed review returned `PASS` with the saved plan matched and no concerns.

A real stdio MCP connection initialized in 499 ms, listed the exact three core tools, and completed a 129 ms search call whose code context contained both the edited implementation and new limit message. Codexa initialization also preserved pre-existing Graphify-like TOML and JSON configuration exactly while adding only its own server entry. The current tool environment does not expose a live external Graphify MCP server, so no external Graphify call is claimed.

Verification on the Exact Source Head

Frozen validation on final code head 2e0c140:

- Build, typecheck, lint, release-path, publish, privacy, and `git diff --check` passed.
- The canonical clean-archive `npm run security:check` passed in 504 seconds: 110/110 Vitest files, 1,247 passes, 1 intentional skip, and no failures. The full security log SHA-256 is `d5862cbf1e4eec1f5c892d2593bb8e8c58574569d65ea62ee5a7286a2434bef2`.
- Claude integration: 28 command smokes and 89 hook smokes (117 total).
- Startup context gate: project kernel 2,823/3,072 bytes; 3/23 direct tools; measured reductions of 87.2% and 69.9% on the guarded surfaces.
- `npm audit`: 0 vulnerabilities.
- Clean public snapshot, package/plugin hygiene, and one-commit source checks passed; the installed-package smoke passed all 31 checks. The preserved 687-file package SHA-256 is `d40d174cce2a7cb505d09497a3707168ce12c08ecd3f8d925e2966efc8bafdf5a`.
- The focused final membership, schema, extraction, artifact-size, integrity, identity, and SessionStart suites passed: 9 files and 49 tests before the size guard, 4 files and 14 tests after it, plus the final revision-2 compatibility schema run at 9/9.

Additional release evidence:

- Eval gate: 21 scenarios, score 1, `rawRgBetter=0`, and zero failures. The exact-head report SHA-256 is `92bcd8a87a88acef3f669c1f1d65b66279feb3ac90c73503515df6ca60ff1e3e`.
- CI-scaled hot-path benchmark after the integrity witness: all 12 gates passed on exact final code head 2e0c140. SessionStart measured 1,151 ms p95 against the 1,000 ms base target and 1,500 ms gate; MCP freshness measured 80 ms p95 against the 500 ms base target and 750 ms gate. Ten of twelve metrics also met their unscaled base targets; adoption missed its soft target by 342 ms. The report SHA-256 is `7a5f20a0b60d2bfc7e1c387d2673200c3bcbaff6ef4f28e30fe959822228c06c`. The 67,763,283-byte index SHA-256 is `b9757051fc43d5cac20dbea26ec3ea68c4d60c07c833410ece5a4d8cc5058ed4`; its 539-byte integrity-manifest SHA-256 is `fa6be57a66cfcf42f0b51dc0717339b5cb0ce6da98df4d1f4ec4b86b120cbbee`.
- A disclosed second benchmark had one isolated 10,966 ms CLI `repo-map` sample and failed that gate. Twenty immediate exact-command probes did not reproduce it: p95 1,120 ms, max 1,194 ms, 20/20 successful, identical output, no locks, and unchanged artifacts. This is retained as host-tail evidence, not silently discarded.
- Pinned v0.12 transport comparison: all gates passed; tool-list reduction 85.3%, advertisement plus discovery reduction 59.2%, startup payload reduction 56.2%, first-result reduction 75.1%, and repeated-result reduction 86.6%. The exact-head report SHA-256 is `85bbd0132ece083f6a27ac644cf955f46a87ad8ff4f818f41e48aa2f713e8b9a`.
- Focused scale regression: 22/22 passed; execution-surface, MCP transport, and coexistence regressions passed.

A faithful cold and warm final-head index of Codexa contained 483 files, 5,504 symbols, 99,086 usage sites, and 43 workflows in 67,763,283 bytes. The 20 Commander and 23 MCP workflows exactly matched production registrations, with zero parser errors; normalized cold/warm index SHA-256 was `d08960e96c0dac38c2daac0902ca2bafa5e85061c6de7ae8eaa5ea31b4101d9d`. Only 2 workflows needed spill membership, for 9 spill entries (5 unique paths) and a maximum of 5 on one workflow. `workflow-path` recovered `command index` and `command semantic-index` from `tests/task-lifecycle.test.ts` even though that test was outside the displayed 20-test cap. `change-plan` then emitted both workflows as required checks while keeping only the caller-declared test editable.

The SDK update initially exposed one brittle assertion that accepted only the old validator wording. `0474276` widened that test to accept both stable wording forms, after which the complete security gate passed without a waiver.

The first PR run then exposed a pre-existing Windows bootstrap race: an output cap could start process-tree termination, but the still-armed stage timer could fire during slow `taskkill` teardown and relabel the earlier output-cap failure as a timeout. `41118bb` preserves the first terminal condition and makes the regression deterministic by forcing teardown across the timer boundary. The focused test passed 3/3 with typecheck, lint, release-path verification, and `git diff --check`; independent review found no P0-P2 issue. No deadline or log bound was relaxed.

Automated PR review then found that the 40-file public `relatedFiles` cap could hide a later production member from internal change-plan, post-edit, proof, and required-check matching. `a6ac9d0` keeps the public/MCP caps unchanged while matching against retained workflow steps and prioritizing every scoped member up to the public 64-file plan bound. Regressions cover production target #41 and a 21-member scope where only the former receipt omission is edited. Five focused files and 36 tests passed with typecheck, lint, and diff checks; independent re-review found no P0-P2 issue.

A fresh exact-head review then demonstrated a stricter case: tests beyond the 20-test cap could still disappear from internal matching because typed workflow steps and production-first related files were also bounded. `ba1f090` replaces that inference with exact pre-cap membership spill data, threads it through plan, workflow query, evidence, post-edit, proof, and required-check consumers, and adds regressions for test #21, test-symbol-only scope, and dependent tests seeded by typed `TEST_COVERS_WORKFLOW` steps. Legacy revision-2 artifacts rebuild, and revision-3 artifacts cannot load with incomplete spill data. Independent semantic review reported no P0-P3 finding.

The exact-head performance preflight then exposed a high-variance startup path: status parsed and materialized the full 67 MiB index only to report compact freshness. `4862bb4` adds the atomic integrity witness and securely hashes the index stream while parsing only bounded status metadata. On clean Node 22, `SessionStart` moved from the observed failing 1,783 ms p95 baseline to 710 ms; MCP freshness moved from an 834 ms outlier/failure to 85 ms p95. The witness does not authorize evidence queries, and malformed/torn/legacy artifacts retain the full-parser fallback. Independent integrity, identity, concurrency, and human init-edit-refresh review found no release-blocking regression. Final review found and closed one publication race before upload: an exported writer could validate a mutable object, yield for directory I/O, and serialize a later mutation. `1eecdd8` now captures the exact serialized index, freshness, witness, and fact membership synchronously before the first await; a regression with a deferred mutation proves the published index remains the value attested.

The final clean-cache preflight then exposed a parser/cache divergence that fixture-only testing had hidden: identical cached source at the same cache version contained 21 MCP markers, while a cold parse of the real registration module contained none. The registry authority is 23 tools. `2e0c140` follows typed options and `Pick` projections to the exact destructured MCP receiver property, rejects mixed HTTP/MCP containers and shadowed look-alikes, advances the parse-cache and index derivation revisions, and asserts the cold production marker set exactly equals the registry. Cold and warm self-index signatures now match at all fact lanes and produce all 43 execution workflows. Independent adversarial re-review found no P0-P2 issue.

Risk-Budgeted Review

Finding weights are critical 8, high 5, medium 3, and low 1. Merge requires no critical or high finding and no more than 4 residual points.

Independent review found and closed five release-significant risks before the source head was published: lexical receiver shadowing in Commander/MCP extraction, test-heavy workflow truncation evicting production files, and eager object-heavy adjacency retention, plus mutable writer input crossing the integrity-witness publication await, and stale parser cache masking production MCP receiver provenance. Regression tests cover each fix. The final correctness, authority, scale, and dependency reviews report 0 critical, 0 high, and 0 medium findings. The first capped-membership P2 and the Windows failure-cause race were closed. The second capped-membership P2 is code-addressed with focused regressions and clean independent re-review; its GitHub thread remains pending final-head publication and exact-head CI/review.

Residual score: **3/10 (within budget)**. Low-risk watch items are the one-time `O(E log E)` canonical typed-array sort used to build a deterministic adjacency index, pathological repetition of large hidden workflow memberships, and intentionally shallow current-file type provenance for unusual merged or shadowed MCP option types. Hidden membership is byte-bounded and rejected before publication; traversal and retained adjacency storage remain explicitly bounded.

Scope Honesty

- New language or framework support: Commander and MCP execution-surface recognition inside existing JavaScript/TypeScript indexing; no new language.
 - Embedded LLM call: no.
 - Public surface: existing CLI/MCP responses gain bounded evidence; no new MCP tool or configuration knob.
 - Dependency change: no new direct dependency; existing MCP SDK updated to 1.30.0 with audited transitive resolutions.
 - Linked issue: none; this is an owner-directed enhancement phase.
-

Rollout, Deployment, and Live Verification

- 1. Require all six exact-head GitHub jobs: `check`, `package-smoke`, `benchmark`, and `worktree-bootstrap` on Ubuntu, macOS, and Windows.
- 2. Resolve every actionable review thread and keep the final residual score at or below 4 before merge.
- 3. Merge the feature PR through the protected `main` branch.
- 4. Use only `.github/workflows/release-please.yml` on `main` with `secrets.RELEASE_PLEASE_TOKEN` to create or update the expected `chore(main): release 0.19.0` PR.
- 5. Inspect and merge that checked release PR. Let the resulting GitHub Release trigger `.github/workflows/npm-publish.yml` with `secrets.NPM_TOKEN`.
- 6. Verify the GitHub release/tag, npm registry version, MCP Registry entry, fresh install, CLI version/startup, and a real MCP initialization/tool call.

No manual tag or direct npm publish is part of this rollout.

Rollback

Before publication, revert the feature commits and rebuild derived indexes under the restored code version. After publication, preserve npm immutability: revert on `main`, ship a corrective patch through the same secret-backed flow, and deprecate the affected version only for a material safety risk.